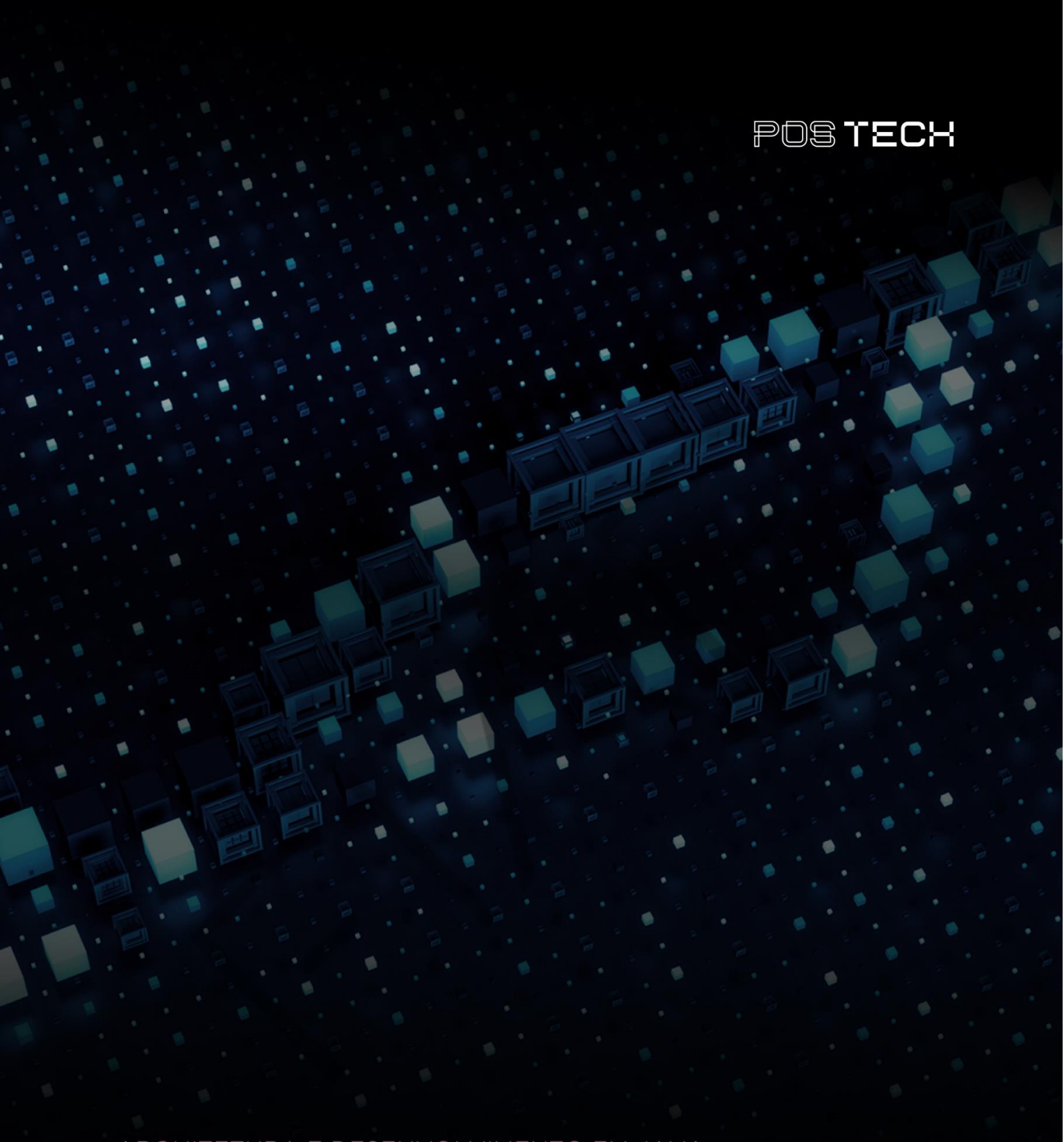


POS TECH

ARQUITETURA E DESENVOLVIMENTO EM JAVA

FASE 3 | AULA 05 -

TESTE DE SEGURANÇA E HANDENING

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

SUMÁRIO

O QUE VEM POR AÍ? 3
HANDS ON 4
SAIBA MAIS 5
O QUE VOCÊ VIU NESTA AULA? 9
REFERÊNCIAS 10
PALAVRAS-CHAVE 11

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

O QUE VEM POR AÍ?

Nessa aula, veremos a implementação de testes de segurança para verificar autorização e autenticação, explorando vulnerabilidades comuns em dois microsserviços desenvolvidos anteriormente, com as ferramentas OWASP ZAP e Fortify. Essas ferramentas são as mais reconhecidas no mercado corporativo por empresas grandes com exigências rigorosas, como bancos, por exemplo.

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

HANDS ON

Nestas videoaulas, implementaremos os principais cenários de testes de segurança em um projeto feito nas aulas anteriores. Além disso, demostraremos a exploração de vulnerabilidades comuns em dois microsserviços desenvolvidos em aula com as ferramentas OWASP ZAP e Fortify.

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

SAIBA MAIS

A implementação de testes automatizados para verificar autorização e autenticação em sistemas que utilizam Spring Security é essencial para garantir a segurança e a confiabilidade de aplicações modernas. Spring Security é amplamente utilizado para gerenciar autenticação, autorização e outras funções de segurança em aplicações Java e, com a crescente sofisticação das ameaças cibernéticas, validar esses aspectos por meio de testes é uma prática indispensável.

As principais razões que destacam a importância desses testes são:

Validação da configuração de segurança: com Spring Security, a configuração de segurança é feita com base em filtros, regras de autorização e políticas de autenticação. Testes automatizados garantem que as regras de acesso estejam configuradas corretamente e funcionando conforme o esperado.

Prevenção de regressões: em sistemas em constante evolução, mudanças no código podem impactar as regras de segurança. Testes automatizados ajudam a identificar regressões e prevenir vulnerabilidades introduzidas inadvertidamente durante atualizações ou novas implementações.

Cobertura de cenários complexos: as permissões de acesso em aplicações corporativas geralmente incluem regras complexas, como controle baseado em papéis (**RBAC**) ou controle baseado em atributos (**ABAC**). Testes automatizados verificam esses cenários em detalhe, cobrindo diferentes combinações de usuários, papéis e permissões.

Confiança no processo de autenticação: com o suporte para autenticação por meio de credenciais, tokens JWT ou provedores externos (**OAuth2**, **OpenID Connect**), garantir que esses mecanismos funcionem corretamente é crucial. Testes automatizados garantem que apenas usuários autenticados possam acessar os recursos protegidos.

Conformidade com políticas de segurança: empresas que operam em setores regulamentados, como saúde ou finanças, devem garantir a conformidade com padrões de segurança. Testes automatizados ajudam a verificar que a aplicação atende às exigências legais, como GDPR ou LGPD, protegendo dados sensíveis.

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

Redução de erros humanos: a configuração manual de regras de segurança pode ser suscetível a erros. Automatizar os testes permite validar de forma consistente e repetitiva se as configurações aplicadas são seguras e funcionais.

Ao implementar **testes de segurança** para autenticação e autorização, você não apenas fortalece a segurança da sua aplicação, mas também melhora a qualidade do software, reduz custos associados a erros de segurança e aumenta a confiança na entrega contínua de valor ao usuário final. No Spring Security, ferramentas como **MockMvc**, **Testcontainers** e o suporte a **testes integrados** tornam esse processo ainda mais acessível e eficiente.

Agora, vamos explorar vulnerabilidades comuns com a ferramenta **OWASP ZAP**. O OWASP (Open Web Application Security Project) é uma organização sem fins lucrativos dedicada à segurança de aplicações. Ela fornece **diretrizes, ferramentas e melhores práticas** para ajudar pessoas desenvolvedoras, arquitetas e equipes de segurança a proteger aplicações web e APIs de ataques cibernéticos.

Segundo lista do OWASP, atualizada em 2021, as dez principais vulnerabilidades em aplicações web são:

1. Broken Access Control (Falha no controle de acesso).
2. Cryptographic Failures (Falhas criptográficas).
3. Injection (SQL Injection, XSS etc.).
4. Insecure Design (Arquitetura insegura).
5. Security Misconfiguration (Configuração insegura).
6. Vulnerable and Outdated Components (Componentes desatualizados).
7. Identification and Authentication Failures (Falhas de identificação e autenticação).
8. Software and Data Integrity Failures (Falhas de integridade de software e dados).
9. Security Logging and Monitoring Failures (Falhas no registro de segurança e no monitoramento).

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

10. Server-Side Request Forgery (SSRF) (Falsificação de solicitação do lado do servidor).

O OWASP ZAP (Zed Attack Proxy) é uma das ferramentas mais conhecidas do OWASP. Ele funciona como um scanner de segurança open-source usado para testes de **pentest em aplicações web**. Suas principais funções são:

1. Detectar **vulnerabilidades web** (SQL Injection, XSS, CSRF etc.).
2. Realizar **ataques automatizados e manuais**.
3. Simular um **hacker** interceptando requisições HTTP/HTTPS.
4. Ser **útil para DevSecOps**, pois pode ser integrado ao CI/CD.

Para utilizar o **OWASP ZAP**, basta fazer o download e executar a ferramenta.

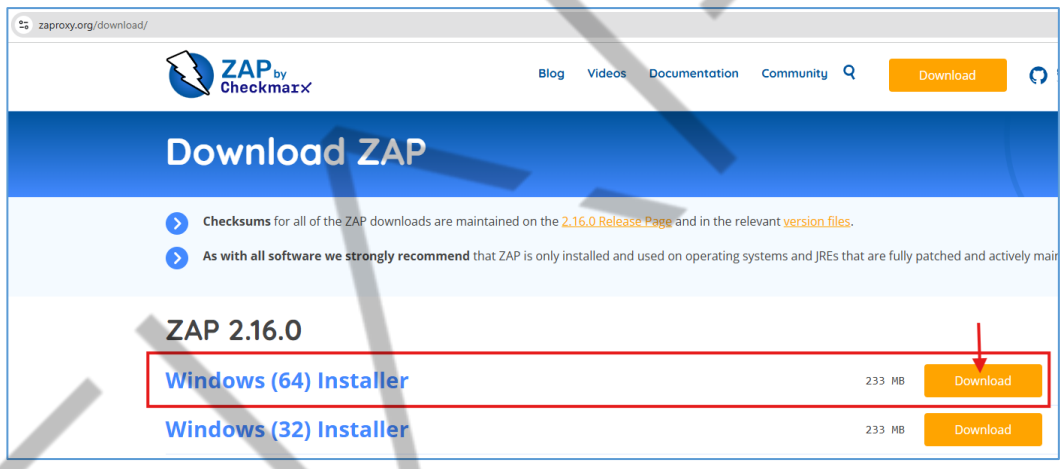


Figura 1 – Download OWASP ZAP
Fonte: elaborado pelo autor (2025)

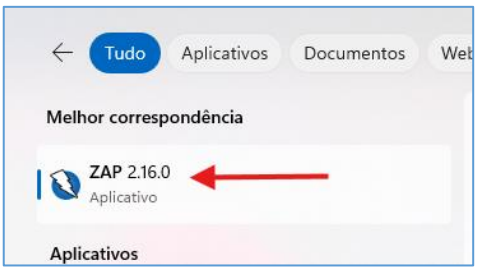


Figura 2 – ZAP
Fonte: elaborado pelo autor (2025)

Para finalizar essa aula, vamos explorar brevemente a ferramenta **Fortify**, uma ferramenta de segurança de software que ajuda a identificar e corrigir vulnerabilidades em código-fonte. Ela oferece soluções de segurança abrangentes e está disponível em diferentes versões, como o Fortify On Demand e o Fortify Static Code Analyzer.

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

A Micro Focus (agora OpenText) **não disponibiliza o Fortify Static Code Analyzer (SCA) gratuitamente para testes** diretamente no site oficial. O Fortify é uma solução corporativa licenciada e requer uma conta empresarial para download.

Você pode entrar em contato com a equipe de vendas da **OpenText** e solicitar uma **versão de avaliação** (Trial). Normalmente, eles oferecem um período de testes mediante aprovação.

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

O QUE VOCÊ VIU NESTA AULA?

Nessa aula, discutimos os principais desafios na segurança em aplicações Java com Spring Security, na versão 6.1, visando o uso atualizado desse componente. Navegamos pelas estruturas (classes/interfaces) do Spring Security e aprendemos a implementar métodos de teste de segurança da nossa aplicação. Vimos pontos importantes para a exploração de vulnerabilidades dos projetos e finalizamos a aula com a exportação desses relatórios.

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

REFERÊNCIAS

BAELDUNG. **Guia do Baeldung**. Disponível em: https://www.baeldung.com/?s=spring%20security. Acesso em: 08 fev. 2025.

NARDONE, M; SCARIONI, C. **Pro Spring Security: Securing Spring Framework 6 and Boot 3-based Java Applications**. New York: Apress, 2023.

SPRING.IO. **Documentação do Spring Security**. Disponível em: https://spring.io/projects/spring-security. Acesso em: 08 fev. 2025.

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com

PALAVRAS-CHAVE

Palavras-chave: spring. security. teste. segurança. vulnerabilidade.

FIAP

PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com



PDF exclusivo para Michelle Ayumi Kashima - rm371026
michelleayumi14@gmail.com